

Penetration Test Report

Target: 192.168.29.71

Date: 2025-04-08

Comprehensive Penetration Test Report

Network Discovery

Open Ports Detection (Informational)

Nmap network scanning results:

```
# Nmap 7.95 scan initiated Tue Apr  8 11:01:26 2025 as: /usr/lib/nmap/nmap --privileged
-sV -sC -oN - 192.168.29.71
Nmap scan report for 192.168.29.71
Host is up (0.00013s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
MAC Address: 08:00:27:7E:E9:08 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

```
# Nmap done at Tue Apr  8 11:01:33 2025 -- 1 IP address (1 host up) scanned in 6.99
seconds
```

Comprehensive Penetration Test Report

Web Application Testing

WordPress Vulnerability Scan (High)

WPScan results for WordPress assessment:

```

_
\ \      / /  _ \ / ____|
 \ \  /\  / / | |_) | (___ _ _ _ _ ®
  \ \  \ / | |__ / \__ \ / _ \| ' _ \
   \ \  /  | |   ___ ) | (___ (___ | | | |
    \ \  /  | |   ___ ) | (___ (___ | | | |
     \ \  /  | |   ___ ) | (___ (___ | | | |
      \ \  /  | |   ___ ) | (___ (___ | | | |
       \ \  /  | |   ___ ) | (___ (___ | | | |
        \ \  /  | |   ___ ) | (___ (___ | | | |
         \ \  /  | |   ___ ) | (___ (___ | | | |
          \ \  /  | |   ___ ) | (___ (___ | | | |
           \ \  /  | |   ___ ) | (___ (___ | | | |
            \ \  /  | |   ___ ) | (___ (___ | | | |
             \ \  /  | |   ___ ) | (___ (___ | | | |
              \ \  /  | |   ___ ) | (___ (___ | | | |
               \ \  /  | |   ___ ) | (___ (___ | | | |
                \ \  /  | |   ___ ) | (___ (___ | | | |
                 \ \  /  | |   ___ ) | (___ (___ | | | |
                  \ \  /  | |   ___ ) | (___ (___ | | | |
                   \ \  /  | |   ___ ) | (___ (___ | | | |
                    \ \  /  | |   ___ ) | (___ (___ | | | |
                     \ \  /  | |   ___ ) | (___ (___ | | | |
                      \ \  /  | |   ___ ) | (___ (___ | | | |
                       \ \  /  | |   ___ ) | (___ (___ | | | |
                        \ \  /  | |   ___ ) | (___ (___ | | | |
                         \ \  /  | |   ___ ) | (___ (___ | | | |
                          \ \  /  | |   ___ ) | (___ (___ | | | |
                           \ \  /  | |   ___ ) | (___ (___ | | | |
                            \ \  /  | |   ___ ) | (___ (___ | | | |
                             \ \  /  | |   ___ ) | (___ (___ | | | |
                              \ \  /  | |   ___ ) | (___ (___ | | | |
                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                 \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                  \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                   \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                    \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                     \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                      \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                       \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                        \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                         \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                          \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                           \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                            \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                             \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                              \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                               \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                                                \ \  /  | |   ___ ) | (___ (___ | | | |
                                                                                                             -

```

WordPress Security Scanner by the WPScan Team

Version 3.8.28

Sponsored by Automattic - <https://automattic.com/>

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[32m[+] [0m URL: <http://192.168.29.71/> [192.168.29.71]

[32m[+] [0m Started: Tue Apr 8 11:01:36 2025

Interesting Finding(s):

[32m[+] [0m Headers

| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)

| Found By: Headers (Passive Detection)

| Confidence: 100%

[32m[+] [0m XML-RPC seems to be enabled: <http://192.168.29.71/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

| References:

| - http://codex.wordpress.org/XML-RPC_Pingback_API

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

|

https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[32m[+] [0m WordPress readme found: <http://192.168.29.71/readme.html>

| Found By: Direct Access (Aggressive Detection)

Comprehensive Penetration Test Report

| Confidence: 100%

[32m[+] [0m The external WP-Cron seems to be enabled: <http://192.168.29.71/wp-cron.php>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 60%

| References:

| - <https://www.iplocation.net/defend-wordpress-from-ddos>

| - <https://github.com/wpscanteam/wpscan/issues/1299>

[32m[+] [0m WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).

| Found By: Most Common Wp Includes Query Parameter In Homepage (Passive Detection)

| - <http://192.168.29.71/wp-includes/css/dashicons.min.css?ver=4.1.31>

| Confirmed By:

| Common Wp Includes Query Parameter In Homepage (Passive Detection)

| - <http://192.168.29.71/wp-includes/css/admin-bar.min.css?ver=4.1.31>

| Atom Generator (Aggressive Detection)

| - <http://192.168.29.71/?feed=atom>, <generator uri="https://wordpress.org/" version="4.1.31">WordPress</generator>

[34m[i] [0m The main theme could not be detected.

[32m[+] [0m Enumerating All Plugins (via Passive Methods)

[34m[i] [0m No plugins Found.

[32m[+] [0m Enumerating Config Backups (via Passive and Aggressive Methods)

Checking	Config	Backups	- :
=====			
=====			
=====			

[34m[i] [0m No Config Backups Found.

[33m[!] [0m No WPScan API Token given, as a result vulnerability data has not been output.

[33m[!] [0m You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>

[32m[+] [0m Finished: Tue Apr 8 11:01:39 2025

[32m[+] [0m Requests Done: 170

[32m[+] [0m Cached Requests: 4

[32m[+] [0m Data Sent: 68.476 KB

Comprehensive Penetration Test Report

[32m[+] [0m Data Received: 66.709 KB
[32m[+] [0m Memory used: 232.426 MB
[32m[+] [0m Elapsed time: 00:00:02

Web Server Vulnerabilities (Medium)

Nikto web vulnerability scanner results:

- Nikto v2.5.0

```
-----  
+ Target IP:          192.168.29.71  
+ Target Hostname:    192.168.29.71  
+ Target Port:        80  
+ Start Time:         2025-04-08 11:01:40 (GMT-4)  
-----  
+ Server: Apache/2.4.18 (Ubuntu)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See:  
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to  
render the content of the site in a different fashion to the MIME type. See:  
https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-typ  
e-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache  
2.2.34 is the EOL for the 2.x branch.  
+ /: Web Server returns a valid response with junk HTTP methods which may cause false  
positives.  
+ /hidden/: This might be interesting.  
+ /xmlrpc.php: xmlrpc.php was found.  
+ /icons/README: Apache default file found. See:  
https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /wp-content/plugins/akismet/readme.txt: The WordPress Akismet plugin 'Tested up to'  
version usually matches the WordPress version.  
+ /wp-links-opml.php: This WordPress script reveals the installed version.  
+ /license.txt: License file found may identify site software.  
+ /wp-login.php?action=register: Cookie wordpress_test_cookie created without the  
httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /wp-login.php: Wordpress login found.  
+ 8102 requests: 0 error(s) and 12 item(s) reported on remote host  
+ End Time:          2025-04-08 11:02:04 (GMT-4) (24 seconds)  
-----
```

Comprehensive Penetration Test Report

+ 1 host(s) tested

Comprehensive Penetration Test Report

Exploitation Attempts

SQL Injection Testing (Critical)

SQLMap injection test results:

```

      ____
     _H_
    ____[(]____ _ {1.9.3#stable}
|_ -| . ['] | .'| . |
|____|_ ["]_|_|_|_|_|_|_|_|
      |_|V...      |_| https://sqlmap.org
```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 11:02:06 /2025-04-08/

```
[11:02:06] [INFO] testing connection to the target URL
[11:02:06] [INFO] testing if the target URL content is stable
[11:02:07] [INFO] target URL content is stable
[11:02:07] [INFO] testing if GET parameter 'id' is dynamic
[11:02:07] [WARNING] GET parameter 'id' does not appear to be dynamic
[11:02:07] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be
injectable
[11:02:07] [INFO] testing for SQL injection on GET parameter 'id'
[11:02:07] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[11:02:07] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[11:02:07] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or
GROUP BY clause (EXTRACTVALUE)'
[11:02:07] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[11:02:07] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING
clause (IN)'
[11:02:07] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[11:02:07] [INFO] testing 'Generic inline queries'
[11:02:07] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[11:02:07] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[11:02:07] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[11:02:07] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[11:02:07] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[11:02:08] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
```

Comprehensive Penetration Test Report

```
[11:02:08] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other
(potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[11:02:08] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[11:02:08] [WARNING] GET parameter 'id' does not seem to be injectable
[11:02:08] [CRITICAL] all tested parameters do not appear to be injectable. Try to
increase values for '--level'/'--risk' options if you wish to perform more tests. If you
suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you
could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch
'--random-agent'

[*] ending @ 11:02:08 /2025-04-08/
```

Password Brute-force Attack (High)

Hydra brute-force attack results:

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) starting at 2025-04-08 11:02:08

[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task

[DATA] attacking

http-post-form://192.168.29.71:80/wp-login.php:log=^USER^&pwd=^PASS^:F=incorrect

[80][http-post-form]	host: 192.168.29.71	login: admin	password: 12345
[80][http-post-form]	host: 192.168.29.71	login: admin	password: iloveyou
[80][http-post-form]	host: 192.168.29.71	login: admin	password: rockyou
[80][http-post-form]	host: 192.168.29.71	login: admin	password: monkey
[80][http-post-form]	host: 192.168.29.71	login: admin	password: 123456
[80][http-post-form]	host: 192.168.29.71	login: admin	password: 123456789
[80][http-post-form]	host: 192.168.29.71	login: admin	password: password
[80][http-post-form]	host: 192.168.29.71	login: admin	password: 12345678
[80][http-post-form]	host: 192.168.29.71	login: admin	password: abc123
[80][http-post-form]	host: 192.168.29.71	login: admin	password: nicole
[80][http-post-form]	host: 192.168.29.71	login: admin	password: babygirl
[80][http-post-form]	host: 192.168.29.71	login: admin	password: princess
[80][http-post-form]	host: 192.168.29.71	login: admin	password: 1234567
[80][http-post-form]	host: 192.168.29.71	login: admin	password: lovely

Comprehensive Penetration Test Report

[80][http-post-form] host: 192.168.29.71 login: admin password: daniel

[80][http-post-form] host: 192.168.29.71 login: admin password: jessica

1 of 1 target successfully completed, 16 valid passwords found

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) finished at 2025-04-08 11:02:10

Comprehensive Penetration Test Report

Security Recommendations

[Critical] Immediately patch SQL injection vulnerabilities

[High] Implement strong password policies and MFA

[Medium] Update WordPress components to latest versions

[Low] Configure proper HTTP security headers